



Мини-сканер безопасности веб-приложения

Автоматическая проверка указанных URL на базовые уязвимости
для начинающих разработчиков и AppSec специалистов

Команда

Рак Алиса Григорьевна · Чумаченко Антон Сергеевич · Вавичкин Илья Александрович
Команда «Метилпропенилендигидроцин»



Актуальность

Ручная проверка безопасности перед релизом требует специальных знаний и отнимает критическое время, про это разработчики рискуют пропустить базовые уязвимости из-за их разнообразия

Кто пользователь

Специалисты AppSec/Разработчики на этапе пре-релизной проверки проектов для выявления грубых ошибок безопасности.

Пользователи сталкиваются с этим когда выкладывают приложения в открытый доступ или перед сдачей/проверкой задания.

На выходе пользователь хочет получить полный отчет об уязвимостях сайта и их возможном решении

Почему это важно в ИБ

Без проверки веб-приложение выходит в свет с реальными брешами, которые злоумышленники могут использовать:

- Компрометация данных – через XSS или SQL-инъекции украдут сессии, личные данные пользователей или получить доступ к БД
- Утечка технической информации упростит подбор целенаправленных эксплойтов

Ручная проверка ненадежна: она дорогая, долгая.

Автоматический скан помогает выявить типовые уязвимости, пока приложение не вышло

Мини-сканер безопасности веб-приложений станет дешевым и быстрым способом для нахождения уязвимостей



Решение и почему именно оно

SpyVision – автоматический сканер уязвимостей веб-приложений

Как работает

Пользователь вводит URL веб-приложения.

Система автоматически исследует сайт, запускает ограниченный набор безопасных проверок.

Итоги тестирования можно скачать в pdf-отчете с самыми опасными ошибками.

Автоматическое тестирование позволит найти уязвимости до их эксплуатации

Почему не аналоги

Тяжелые профессиональные сканеры (к примеру OWASP ZAP) требуют сложной настройки и ручной конфигурации, без которой дают вам ложную информацию

Онлайн-сервисы проверки безопасности (VirusTotal и т.д.) ограничены поверхностной разведкой и не умеют тестировать параметры ввода и формы из-за чего не находят XSS и SQL-инъекции.

Наш мини-сканер не требует настройки, но при этом находит уязвимости ввода и не только. Ограничения интенсива учтены

SpyVision – простой в использовании сканер



Что входит в MVP

Делаем сейчас

Сканер уязвимостей веб-приложений для безопасной публикации сервиса в открытый доступ

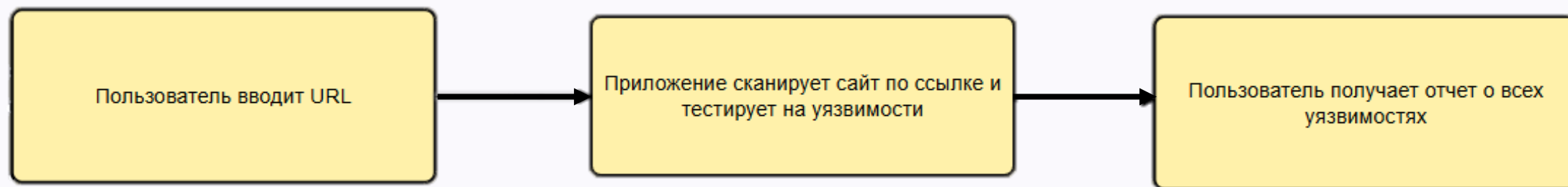
Примером для демонстрации функций сканера является сайт VulnShop

Ограничения проекта

- Продукт локальный
- Без платных API

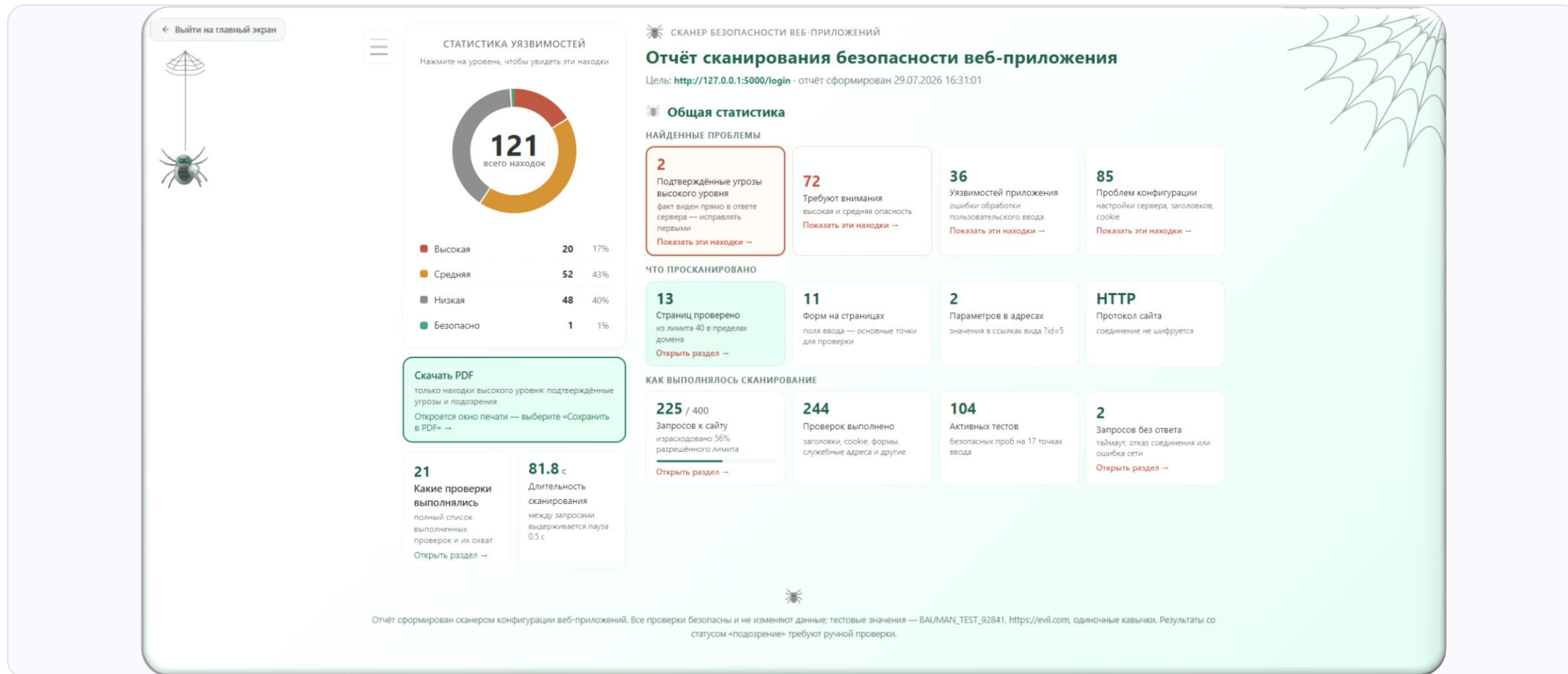
Логика работы

Нарисовать схему (алгоритм работы)





Демонстрация продукта





Итог и что дальше

За неделю был разработан мини-сканер

Сделали

Рабочий MVP на учебных данных

Пользователь скачивает наше приложение, вводит URL, после чего происходит сканирование веб-приложения и сайт выдает данные об уязвимостях, что можно скачать в pdf отчете

Провели проверку на предзащите

Планы развития

Более глубокий сканер и просмотр форматов внутри сайта на уязвимости



ВОПРОСЫ?



***Данный слайд будет редактироваться, чуть более научный подход тут, он будет вторым**

Цели проекта

- Изучить работу сканеров уязвимостей и возможные уязвимости